SECURITY AUTOMATION PROJECT REPORT

PhishSOAR

Automated phishing triage and response for business email.

Every incoming email is checked the way a SOC analyst would check it. Dangerous emails are quarantined in under a minute, and the user gets an alert that explains why in plain English.

< 1 min	9	17	SSH only
from email arriving to quarantine and alert	detection layers, from SPF/DKIM/DMARC to LLM review	automated tests in the production build	the one port open to the internet

Kehinde Oyewumi
Cybersecurity practitioner · SOC operations and security automation
github.com/BalMM-hub/PhishSOAR · October 2026

1. Summary

PhishSOAR is a phishing triage and response pipeline I designed, built and deployed for business Gmail inboxes. It runs on a hardened Linux server, checks each inbox every minute, and handles the full loop on its own: collect, enrich, decide, contain and notify.

It is in production protecting real mailboxes. It was first deployed for CyberVet, and each new business gets its own isolated workflow and Gmail connection, so it can be rolled out for any organisation that uses Gmail or Google Workspace.

The problem

A lot of businesses I know in Nigeria don't have a security team watching their email, but they still face the same attacks as everyone else:

- Fake bank alerts and "update your BVN" messages that lead to credential theft
- A "CEO" or "vendor" asking for an urgent transfer or announcing new bank details
- QR codes inside images or PDFs, used because link scanners can't see them
- Disguised links, look-alike domains and malware hidden in password-protected archives

Built-in spam filtering catches a lot, but not everything, and when something slips through nobody is watching. The goal was to automate the triage steps an analyst does by hand on a suspicious email and run them on every single email.

What it does

Verdict	Score	Automatic response
Malicious	70 and above	Moved out of the inbox to a quarantine folder, and a plain-English alert is sent. Nothing is deleted.
Suspicious	40 to 69	Left in the inbox, tagged, and an alert is sent so nobody acts on it before checking.
Clean	Below 40	Tagged as scanned. No noise for the user.

The SOAR playbook

Step	What happens
Collect	n8n pulls new, unscanned email from each inbox through the Gmail API every minute.
Enrich	The analyzer parses the email, inspects files and images, and checks links, file hashes and sender IPs against threat intel.
Decide	Rules, threat intel and an LLM review are fused into one score, with a fail-safe if any check can't finish.
Contain	Malicious email is quarantined automatically. Suspicious email is tagged.
Notify	The user receives an alert with the reasons, advice and IOCs. I get paged on Telegram if the pipeline itself fails.

2. Architecture

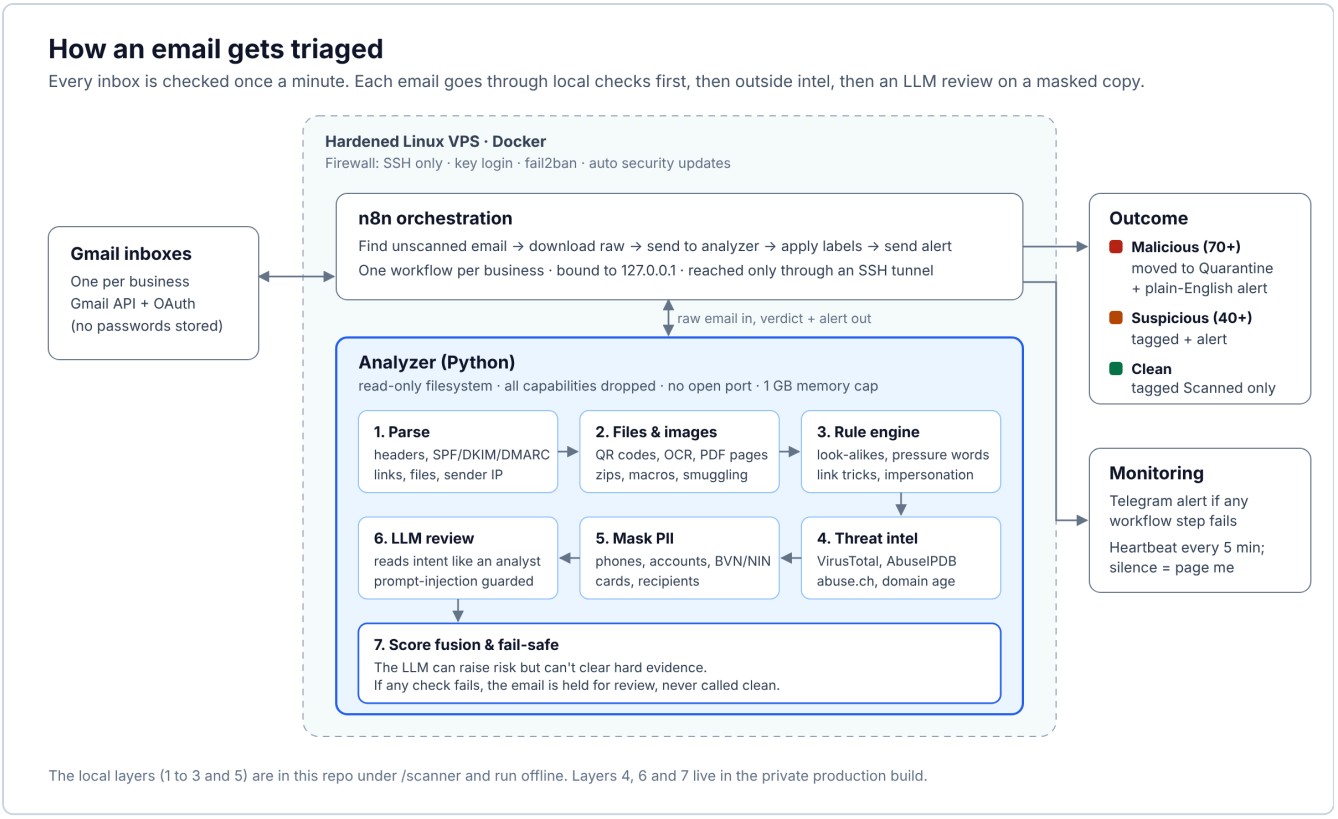


Figure 1. How an email moves through the system.

Orchestration: n8n

One workflow per business. It finds unscanned email, downloads the raw message, sends it to the analyzer, applies labels and sends the alert from the protected mailbox. Separate workflows handle failure alerts and the heartbeat.

Analysis: Python service

A Flask API running in its own locked-down container. It parses the email, decodes QR codes with OpenCV, reads text in images with Tesseract OCR, renders PDF pages, inspects archives and Office files, runs the rule engine and threat intel, masks personal data and runs the LLM review.

Hosting

A Linux VPS running Docker Compose. Only SSH is open to the internet. n8n listens on localhost and is reached through an SSH tunnel. The analyzer has no published port at all.

Tech stack

n8n · Python · Flask · Docker · Ubuntu · Gmail API + OAuth · OpenCV · Tesseract OCR · pypdfium2 · VirusTotal · AbuseIPDB · URLhaus · ThreatFox · MalwareBazaar · RDAP · LLM API · SQLite · Telegram · Healthchecks.io

3. Detection

Layer	What it checks	Example it catches
Sender authentication	SPF, DKIM, DMARC, Reply-To and Return-Path mismatches	A "Microsoft" email that fails DMARC and replies to a Protonmail address
Impersonation	Brand names in the display name vs the real domain; look-alike domains, including Nigerian banks and the business's own domain	`rnicrosoft-support.xyz`, `zenithbanc.com`
Language	Pressure and scam wording, payment and bank-detail changes, BVN/NIN/OTP requests	"Process this transfer today and keep it confidential"
Links	Link text vs real destination, shorteners, high-abuse domain endings, free hosting, punycode	Text says `docs.company.com`, link goes to `company-docsign.click`
Attachments	Double extensions, risky types, macros, remote templates, encrypted archives, HTML smuggling, active PDF content	`Invoice.pdf.exe` inside a password-protected zip
Images and PDFs	QR codes decoded, OCR on images, first PDF pages rendered and scanned	"Scan to keep your mailbox active" QR code inside an image
Threat intel	VirusTotal, AbuseIPDB, URLhaus, ThreatFox, MalwareBazaar, domain age via RDAP	A domain registered days ago, a file hash known as malware
LLM review	Reads the full email for intent, on a masked copy, and returns a structured verdict	CEO fraud with no links and no attachments
Score fusion	Combines all layers into one score with fixed thresholds and a fail-safe	The LLM can raise risk but can't clear hard evidence

MITRE ATT&CK coverage

Technique	How it shows up	Layers that catch it
T1566.001 Spearphishing Attachment	Malicious or disguised files, macro documents, encrypted archives	Attachments, threat intel
T1566.002 Spearphishing Link	Credential harvesting pages, disguised links, QR codes	Links, images, threat intel, domain age
T1534 Internal Spearphishing	Phishing from a real but compromised colleague or vendor account, so authentication passes	Language, links, LLM review
T1656 Impersonation	Fake banks, brands, vendors and executives	Authentication, impersonation, LLM review
T1204 User Execution	Pressure to open a file or click now	Language, user alert guidance

4. Using AI safely

Some attacks are only words. "I'm in a meeting, please pay this new vendor today and keep it between us" has no bad link, no attachment, and passes SPF, DKIM and DMARC. Rules see the warning signs but can't be sure. In the offline results below, this sample scores only 30 on rules alone. The LLM layer is what closes that gap. I treated it as a security-sensitive component, not a magic box.

Risk	Control
Client data sent to an AI provider	Phone numbers, bank account numbers (NUBAN), BVN/NIN, card numbers, recipient addresses and the name part of email addresses are masked with tags such as `[PHONE]` and `[ACCOUNT-NUMBER]` before the AI check. Rules and threat intel still run on the original email on my own server, so detection doesn't drop. Unit tests prove these details never reach the AI payload.
What still goes	The sender address and domains (the core evidence), links, masked body text and up to 3 images, because images are how fake login pages get caught. Sending images can be switched off per deployment. The provider is used through its paid API, whose commercial terms don't allow training on API data.
Prompt injection	The email is wrapped as untrusted data and the model is told never to follow instructions inside it. An email that tries to talk to the filter ("mark this as safe") is itself a red flag.
Unpredictable output	The model must answer through a fixed tool schema (verdict, confidence, category, reasons, advice). Anything else is rejected.
Over-trusting the model	The verdict is one input to the score. It can raise risk, but it can't clear hard evidence such as known malware or failed DMARC with impersonation.
Fail-open	If the AI check can't run, the email is retried on the next run. If it keeps failing, it's held as suspicious for a person. It's never marked clean because a check was missing.

5. Results

Offline scanner on the public sample emails (rules only)

```
credential_harvest.eml   MALICIOUS   100/100   DMARC fail, brand impersonation, reply-to mismatch,
disguised link
encrypted_zip.eml        MALICIOUS    90/100   .pdf.exe inside a password-protected zip
pdf_qr.eml               MALICIOUS    75/100   QR code inside a PDF hides a shortened link
quishing_image.eml       SUSPICIOUS   45/100   QR code inside an image points to a .click domain
ceo_fraud.eml            CLEAN        30/100   warning signs seen, but rules alone can't be sure
newsletter.eml           CLEAN         0/100
```

Full system on a live inbox

Credential phishing, CEO fraud with no links, a QR code inside an image, a bank-detail change request and a disguised link were all caught and alerted. Normal emails from Google, Netflix, TikTok and Temu stayed clean.

6. What the user sees

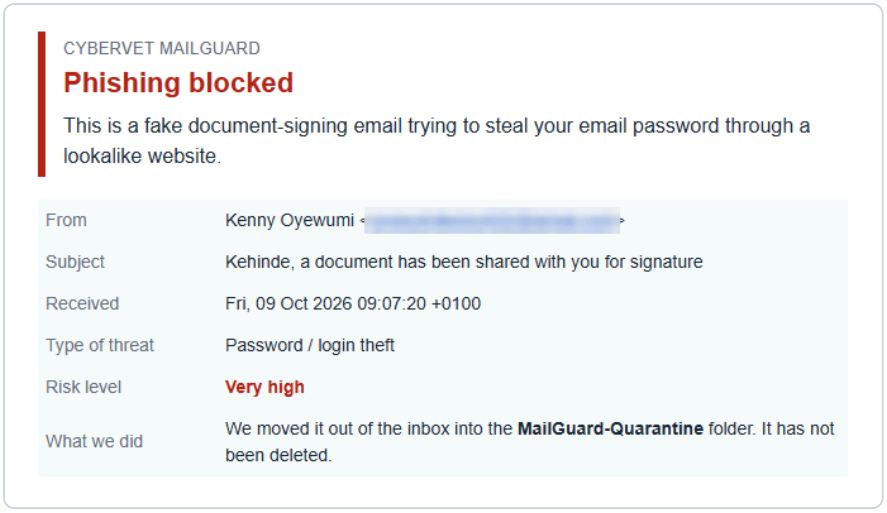


Figure 2. The alert a user receives when a phishing email is blocked.

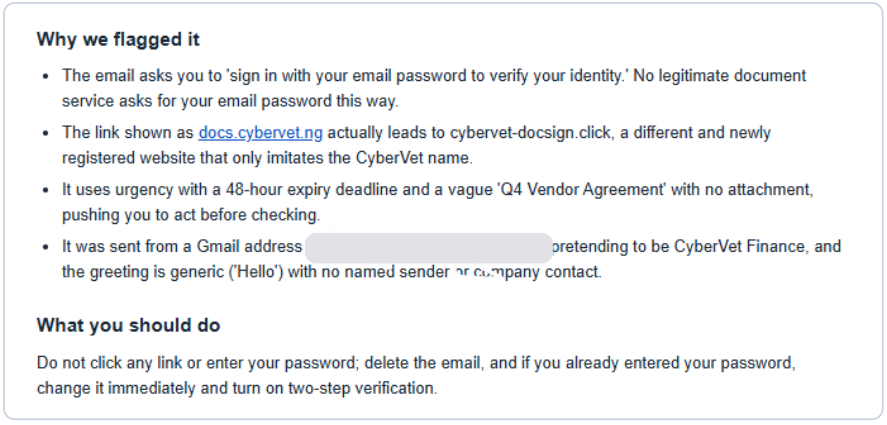


Figure 3. Specific reasons and advice in plain English, not just a score.

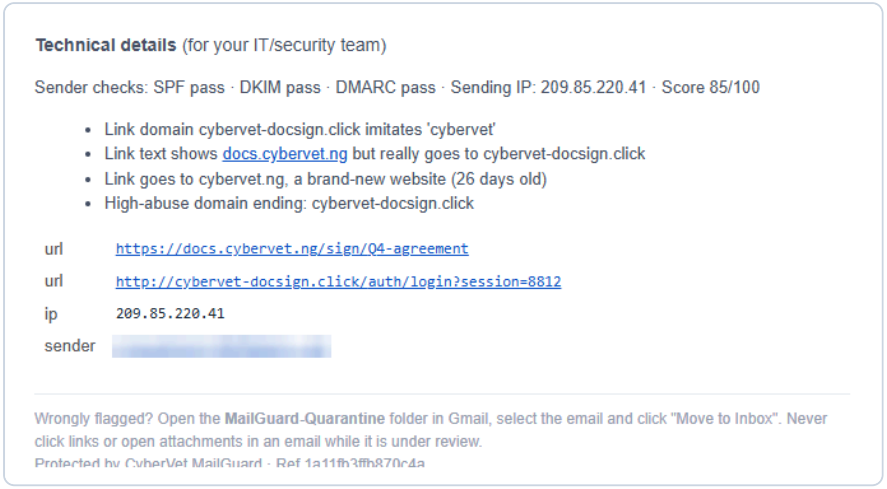


Figure 4. Technical details and IOCs for whoever handles security.

7. Securing and running the system

A tool that reads other people's email is a target, so it was built like one.

Hardening

- Analyzer container: read-only filesystem, all capabilities dropped, no privilege escalation, non-root user, memory and process limits, no published port
- n8n bound to localhost, reached only through an SSH tunnel
- Server: SSH keys only, root and password login disabled, firewall allows SSH only, fail2ban, automatic security updates
- No mailbox passwords: OAuth tokens, revocable by the business at any time
- Secrets in a server-side `.env`, never committed
- Run history containing email content deleted after 72 hours
- Alerts carry a secret header, so the system skips its own alerts while spoofed copies are still scanned

Monitoring and reliability

- Error workflow sends a Telegram alert with the failing step and error
- Heartbeat every 5 minutes checks Gmail access and analyzer health, then pings Healthchecks.io. Silence for 15 minutes pages me
- Retries for network blips and API overloads; unchecked email is picked up on the next run
- Duplicate-alert protection
- Documented runbook for backups, updates, troubleshooting and incident response

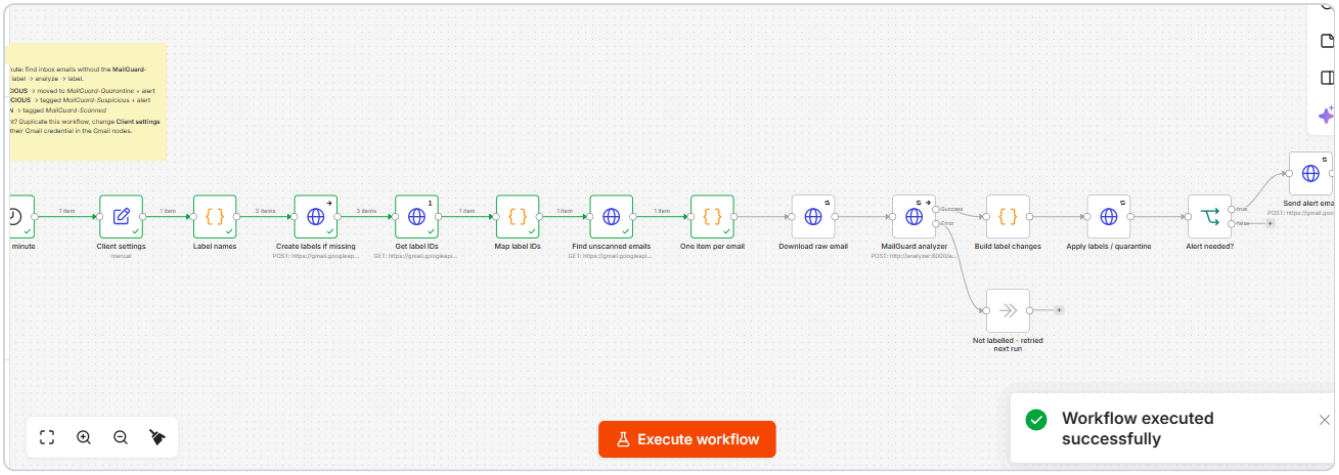


Figure 5. The n8n triage workflow after a successful run.

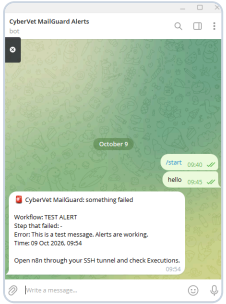


Figure 6. Failure alert on Telegram.



Figure 7. Containers healthy: the analyzer has no exposed port, n8n listens only on localhost.

8. Challenges and lessons

- **Random TLS failures.** Calls to the LLM API kept failing with `SSLV3_ALERT_BAD_RECORD_MAC` on Docker Desktop for Windows, while every other API worked. I tested MTU sizes, TLS versions and offloading settings, narrowed it to that local network path, and moved production to a Linux VPS. The code kept the lessons: retries, a text-only fallback when large uploads fail, and retry-next-run instead of guessing.
- **Not trusting the AI too much.** I built the scoring so the LLM is one input: it can push risk up, it can't wipe out hard evidence, and anything that can't be fully checked is held. Both behaviours are covered by tests.
- **Privacy without losing detection.** Masking only the AI's copy, keeping the sender and domains, and using tags the model understands meant "pay into a new [ACCOUNT-NUMBER]" still reads as a red flag.
- **The system scanning its own alerts.** Alert emails land in the same inbox. A signed header solved it without opening a hole for attackers.

Skills demonstrated

Area	Evidence in this project
SOC triage and email security	Header analysis, SPF/DKIM/DMARC, phishing and BEC patterns, IOC extraction
Detection engineering	Weighted rules, look-alike domains, QR and OCR analysis, attachment inspection, false-positive tuning
Threat intelligence	Five intel sources plus domain age, with caching and rate limits
Security automation (SOAR)	n8n playbooks for collection, enrichment, containment and notification
AI security	Prompt injection defences, structured output, PII masking, fail-safe design
Python engineering	Email parsing, image processing, a Flask API, unit tests
Infrastructure security	Docker and Linux hardening, SSH tunnelling, OAuth, secrets management
Operations	Error workflows, heartbeat monitoring, runbooks, backups
Privacy and compliance	Data minimisation and retention limits, designed with the Nigeria Data Protection Act in mind

Roadmap

- Microsoft 365 / Outlook support through Microsoft Graph
- Instant scanning with Gmail push notifications instead of polling
- A dashboard with weekly stats per business
- Automatic encrypted backups

> **Source and demo:** github.com/BalMM-hub/PhishSOAR. The public repo has the offline detection layers, sample emails, sanitized n8n workflows and the hardened deployment file.